

Security and Compliance Plan

Stripe processes billions of financial transactions annually, making the data it handles particularly sensitive. This data also includes personal information and confidential business information. This document describes the security framework implemented to protect this data and ensure regulatory compliance.

1. Data Encryption

Encryption is differentiated according to two types of data: data in transit and data at rest.

Regarding data in transit, all communication between systems must use the SSL/TLS protocol. Data is therefore encrypted during its transport between PostgreSQL, Kafka, MongoDB, and Snowflake. Communication between Stripe and its customers, via their browser and mobile application, must use the HTTPS protocol. This ensures that no one can intercept payment data. Finally, credit card data must be transmitted as an encrypted token, never in plain text over the network.

As for stored data, all databases must use Transparent Data Encryption (TDE). Thanks to this, files stored on hard drives are automatically encrypted. Bank card numbers must never be stored in plain text and must therefore be tokenized. Encryption keys must be managed by a Key Management Service. They will then be stored in a location separate from the data to prevent data access from granting access to the keys. Backups must also be encrypted before being stored on S3.

2. Access Control via RBAC

Role-Based Access Control must be implemented on all systems. This ensures that each user only has the permissions associated with their role. The defined roles are: "Admin" has full access to all systems. "Data Engineer" has read and write access to PostgreSQL, Snowflake, and MongoDB. "Data Analyst" has read-only access to Snowflake Analytics. "Developer" has read and write access to OLTP tables only. The Compliance Officer has read-only access to the "fact_compliance" database and audit logs. The principle of least privilege is applied, meaning no one has more access than they need. Multi-factor authentication (MFA) is mandatory for all database access. Access is reviewed regularly; an employee who changes positions automatically loses their previous access. Furthermore, credentials, such as passwords and API keys, are stored in a secure vault, like HashiCorp Vault.

3. Audit Logging

All access to sensitive data must be automatically logged in "fact_compliance" within the OLAP. Each audit log contains: the person who accessed the data (user_id); when they accessed the data (timestamp); what they did (table and action); and from where they accessed it (ip_address). These logs are immutable; no one can modify or delete them. They are stored on PostgreSQL and must be kept for at least one year to meet regulatory requirements. The logs must be analyzed in real time to detect suspicious behavior, such as a user accessing thousands of customer records in a few minutes.

4. GDPR Compliance

The General Data Protection Regulation (GDPR) applies to all data of Stripe's European customers. It includes the right to be forgotten: a customer can request the deletion of their data. A cascade of deletions must then be automatically triggered in all three systems via the Data Control Panel (DCP). Consent must be explicit. Stripe must request and record the consent of each of its European customers regarding the use of their data. Only strictly necessary data should be collected. For example, the full number of a payment card is not stored, only its last four digits. Data portability must be ensured. A European customer can therefore request the export of all their data in a readable format. In the event of a data breach, Stripe must notify the authorities within a maximum of seventy-two hours. The data of its European customers must be stored in data centers on the same continent. A Data Protection Officer must be assigned to oversee GDPR compliance.

5. PCI-DSS Compliance

As a company that processes credit card payments, Stripe must comply with the PCI-DSS (Payment Card Industry Data Security Standard). Card numbers must never be stored in plain text, but rather replaced by tokens. The systems that process card data are isolated within a secure network zone. These systems must be scanned regularly for security vulnerabilities. Penetration tests must be conducted at least annually to identify weaknesses. All systems are regularly updated to patch known vulnerabilities. The data centers that host card data are physically secured. Because Stripe processes over six million transactions annually, the company must be PCI-DSS Level 1 certified, the highest level of compliance.

6. Automated Reporting and Monitoring

Real-time security monitoring must be implemented. The system must continuously monitor for suspicious behavior. This includes unusual access to sensitive data, repeated failed login attempts, abnormal transaction volumes, and access from unusual countries. Alerts must be sent immediately via email and Slack to the security team.

Compliance reports must also be automated. They are automatically generated from the "fact_compliance" function in OLAP. Several types of reports are required. Daily reports list access to sensitive data. Weekly reports summarize security incidents. Monthly reports detail GDPR and PCI-DSS compliance. Regarding the tools used, Snowflake Access History monitors all data access within Snowflake. MongoDB Audit Log records all access to MongoDB. PostgreSQL logs all OLTP operations, and Airflow Monitoring tracks the execution of data pipelines.

Encryption protects data from unauthorized access. RBAC ensures that each user only accesses the data they need. Audit logging tracks every access to sensitive data. GDPR and PCI-DSS compliance protects Stripe from regulatory penalties, and automated monitoring enables the rapid detection of security incidents. All of these measures allow Stripe to meet the most stringent regulatory requirements.